Kasi Yedumati · Full Stack Training

Ticket: CampusCart Auth (JWT lite)

Customer: CampusCart catalog screen
Need: Anyone may **browse** snacks (`GET /products`). Only a **logged-in** user may **add** a snack (`POST /products`). Staff register and login with email + password. The API returns a **JWT**. POST sends `Authorization: Bearer <token>`. Passwords are **BCrypt hashes** in MySQL — never the raw string.

Teaching-order: Keep kit 18 persistence (entity, repository, DTOs, `@Valid`, lite 400). Add `spring-boot-starter-security`, `AppUser`, register / login, **BCrypt**, **JWT** (jjwt), `SecurityFilterChain` (Boot 3 — **not** `WebSecurityConfigurerAdapter`). GET catalog stays public. POST catalog needs a token → **401** without it. **Lab 06 freeze** also requires GET by id **200**/**404** and POST with Bearer + blank name **400** (token present). Secret from env (`JWT_SECRET`, 32+ chars). `jakarta.*`. No OAuth2 / refresh tokens / admin roles. No Lombok. CORS Stretch only (**Later —** React).

Each of `starter/`, `broken/`, and `solution/` is a Maven tree. Open the folder that contains **`pom.xml`**.

Starter

Product list / get / create DTOs are already filled (kit 18). Complete TODOs in `AppUser`, `SecurityConfig`, `JwtService`, `JwtAuthFilter`, and `AuthController`. Export env from `.env.example` including **`JWT_SECRET`**. Import `CampusCart_Auth_v1.postman_collection.json`.

Broken

Raw password saved. `NoOpPasswordEncoder`. `permitAll` on every URL. Fake JWT string. Secret and MySQL password literals in yml. Filter never reads `Authorization`. Fix until curl / Postman match Done when.

Postman

File: `CampusCart_Auth_v1.postman_collection.json`. **Import** in Postman. Variable `baseUrl` = `http://localhost:8080`. Run **Register** (or **Login**) before **Create product with Bearer**.

Run

```
# from kit root
export MYSQL_PASSWORD='your_lab_password'
export MYSQL_USER=root
export MYSQL_DATABASE=training_db
export JWT_SECRET='change_me_lab_jwt_secret_32chars!'

cd starter          # or broken / solution
mvn spring-boot:run
```

Second terminal:

```
curl -s -X POST http://localhost:8080/auth/register \
  -H "Content-Type: application/json" \
  -d '{"email":"priya@campuscart.in","password":"IdliDosa8"}'
# copy token from JSON

curl -s http://localhost:8080/products
```

```
curl -s -o /dev/null -w "%{http_code}\n" -X POST http://localhost:8080/products \
  -H "Content-Type: application/json" \
  -d '{"name":"Pani puri","priceInr":30}'
# expect 401

curl -s -X POST http://localhost:8080/products \
  -H "Content-Type: application/json" \
  -H "Authorization: Bearer PASTE_TOKEN" \
  -d '{"name":"Pani puri","priceInr":30}'
# expect 201
```

Lab 06 freeze (same kit — do not start kit 20)

Demo day **locks** the IN list. Stretch may exist in the repo; it is **not** required to pass.

IN: MySQL catalog + DTOs + `@Valid` + lite **400** / **404** + register / login JWT + public GET + protected POST + README / Postman / screenshots (no live URL).

OUT: deploy / Actuator / PaaS, OAuth2, refresh tokens, admin roles, React, required DELETE / CORS / Lombok, kit 20.

Peer break-auth (use `broken/` or a partner clone — diagnose, do not invent new attacks):
1. Plain password / `NoOpPasswordEncoder` — Workbench shows `IdliDosa8` instead of `$2…`
2. Missing Bearer / filter never reads `Authorization`
3. `permitAll` on every URL — POST **201** with no token
4. JWT secret or DB password literal in git

Done when

- [ ] `mvn spring-boot:run` starts (Tomcat + DataSource + Security)
- [ ] `POST /auth/register` → **201** JSON with `token` + `email` (no password field)
- [ ] Password in MySQL is a **BCrypt** hash (starts with `$2`), not `IdliDosa8`
- [ ] `POST /auth/login` with wrong password → **401**
- [ ] `GET /products` works **without** a token (**200**)
- [ ] `GET /products/{id}` → **200** existing / **404** missing (lite JSON) **without** a token
- [ ] `POST /products` without token → **401**
- [ ] `POST /products` with `Authorization: Bearer …` → **201**
- [ ] `POST /products` with Bearer + blank name → **400** (`error` + `fields`) — not 401
- [ ] Duplicate register email → **409**
- [ ] `JWT_SECRET` and DB password are not literals in git
- [ ] Postman collection v1 imports; freeze requests (401 / 201 / 400 with Bearer / 404 / 409) match
- [ ] README freeze IN/OUT + screenshots + 2–5 min demo (Standard Project Deliverables — **no** live URL)
- [ ] Peer can name the four break-auth smells and the module 05 fix
- [ ] No OAuth2, refresh tokens, Lombok, or admin-role matrix required
- [ ] CORS / extra fields / DELETE **not** required to pass
- [ ] `target/` gitignored

Stretch

- `@CrossOrigin(origins = "http://localhost:5173")` — **not** Done when.
- Extra claim on JWT (e.g. `uid`) — not Done when.
- HTTP DELETE `/products/{id}` still authenticated — optional.
- **Later —** refresh tokens, OAuth2, role-based admin. **Later —** React login form.
- Lombok / records — optional, not in Done when.

Lab 07 (same kit — do not start kit 20)

Lab 06 **Done when** above stays frozen. Lab 07 is **additive** on this API. Notes: `09_Spring_Boot/07_Lab_Deploy_Capstone_Debug.md`.

IN: `spring-boot-starter-actuator`; public **`GET /actuator/health`**; host env (`MYSQL_*`, `JWT_SECRET`, `SPRING_PROFILES_ACTIVE`); `.env.example` in git, never `.env`; local **JAR** + health; PaaS **live URL or blocked-by-platform note**; capstone **M0** (public GitHub + Maven + README). Handmade `/health` is **not** the proof.

OUT: extra Actuator endpoints as pass, custom `HealthIndicator` required, Docker / K8s, WAR + external Tomcat, OAuth2 / refresh / roles, CORS / React, cart / orders (M1–M3), kit 20, Lombok required.

Lab 07 Done when

- [ ] Actuator starter on this pom; `GET /actuator/health` without token → **200** JSON `status` UP (or honest DOWN)
- [ ] `SecurityFilterChain` permits **only** `/actuator/health` (POST `/products` still **401** without Bearer)
- [ ] No MySQL password / JWT secret literals in git; `.env.example` lists `MYSQL_*`, `JWT_SECRET`, `SPRING_PROFILES_ACTIVE`
- [ ] Local proof: `mvn -DskipTests package` + `java -jar` + curl health
- [ ] PaaS: live health URL **or** blocked note + local proof
- [ ] Capstone **M0**: public repo + Maven + README (this API as auth/catalog shell) — not cart/orders
- [ ] Standard Project Deliverables — deploy URL **or** Lab 07 proof

Lab 07 Stretch

- Extra Actuator endpoints (`info`, `metrics`) behind auth — **not** Done when.
- Custom `HealthIndicator` — not Done when.
- Docker image for the JAR — not Done when.
- Kubernetes probes — not Done when.